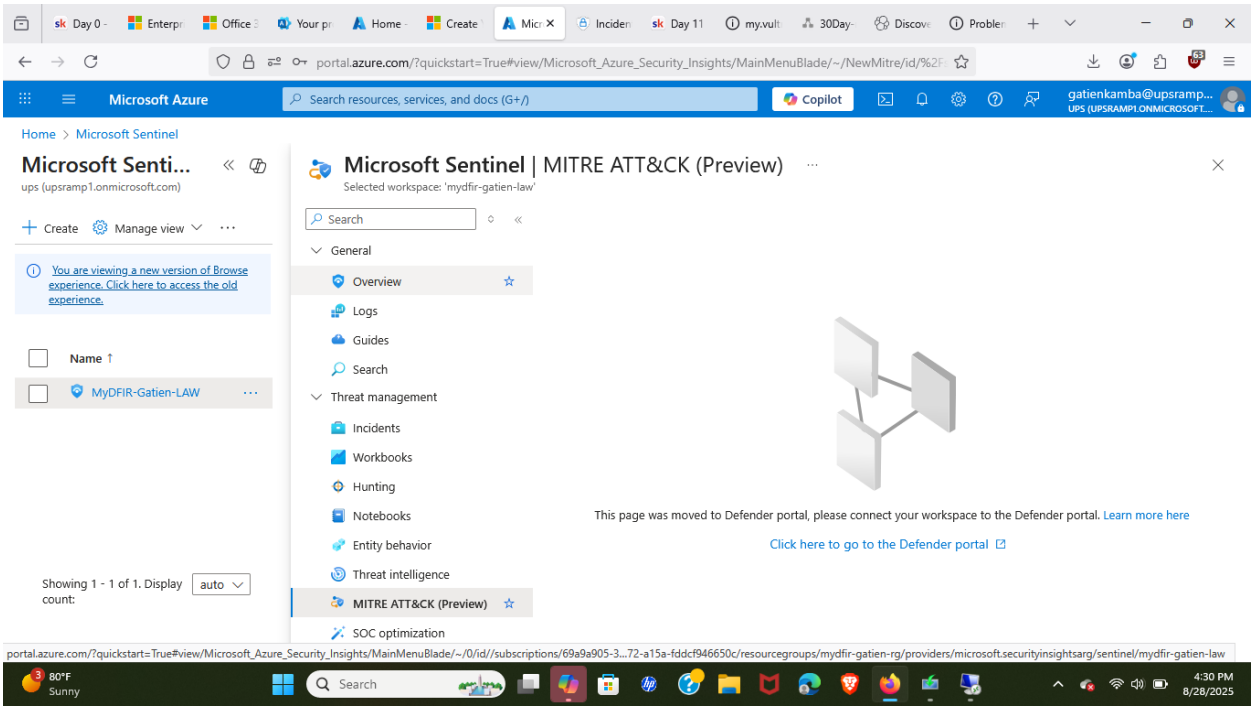
- **Microsoft Sentinel / Defender SOC Lab — Step-by-Step**

1. Microsoft Sentinel / MITRE ATT&CK

The first step was to access the Microsoft Sentinel workspace and examine the MITRE ATT&CK tab. This creates the SIEM environment and allows us to understand how we can map the security detections to the attacker tactics.

SOC skill: How Sentinel maps detection and threat management capabilities with MITRE ATT&CK.

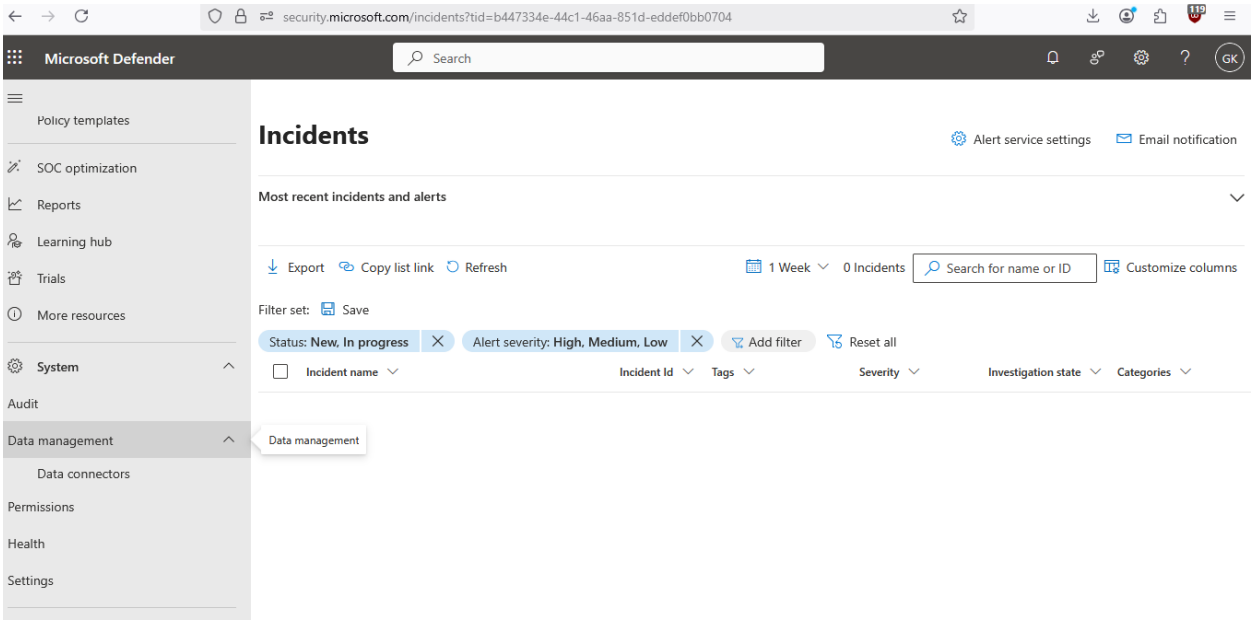


2. Microsoft Defender Incidents

I opened the **Microsoft Defender Incidents** page to review security incidents and alerts.
I looked at information such as:

- Incident name
- Severity
- Investigation state
- Status
- Categories

SOC skill: Alert monitoring and triage.

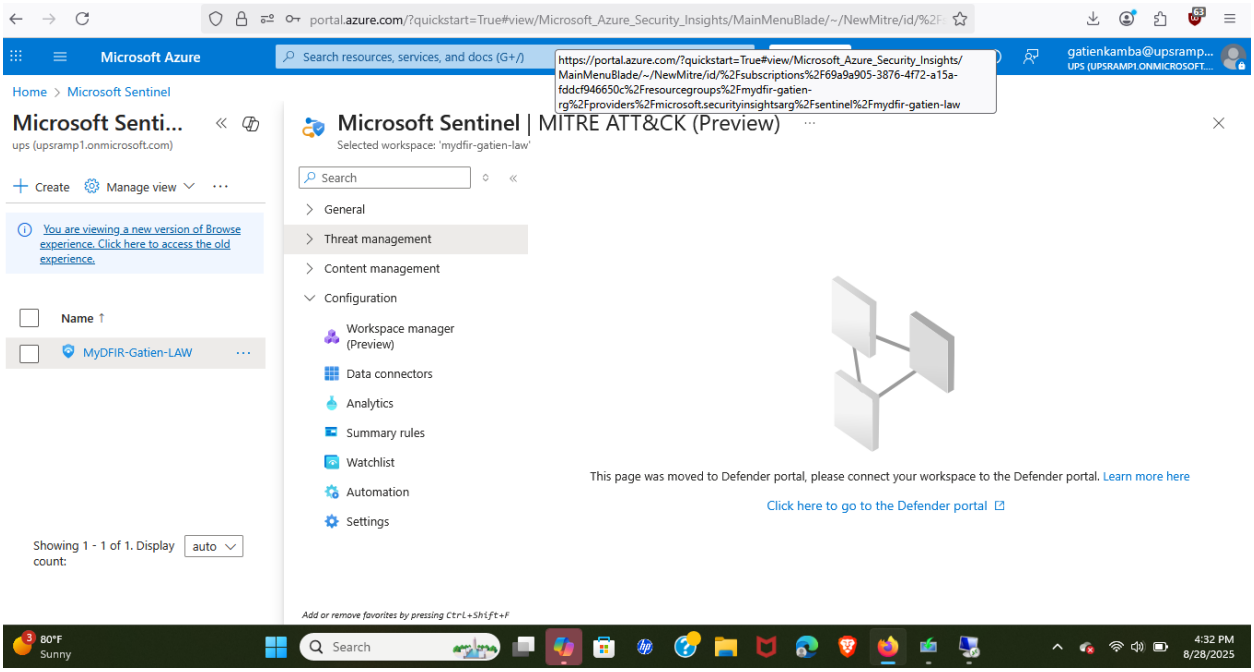


3. Sentinel Analytics

I went to Sentinel → Analytics to look at the detection rule area.

It is where SOC analysts can build and maintain detection rules for identifying suspicious activity.

SOC skill: Detection engineering.



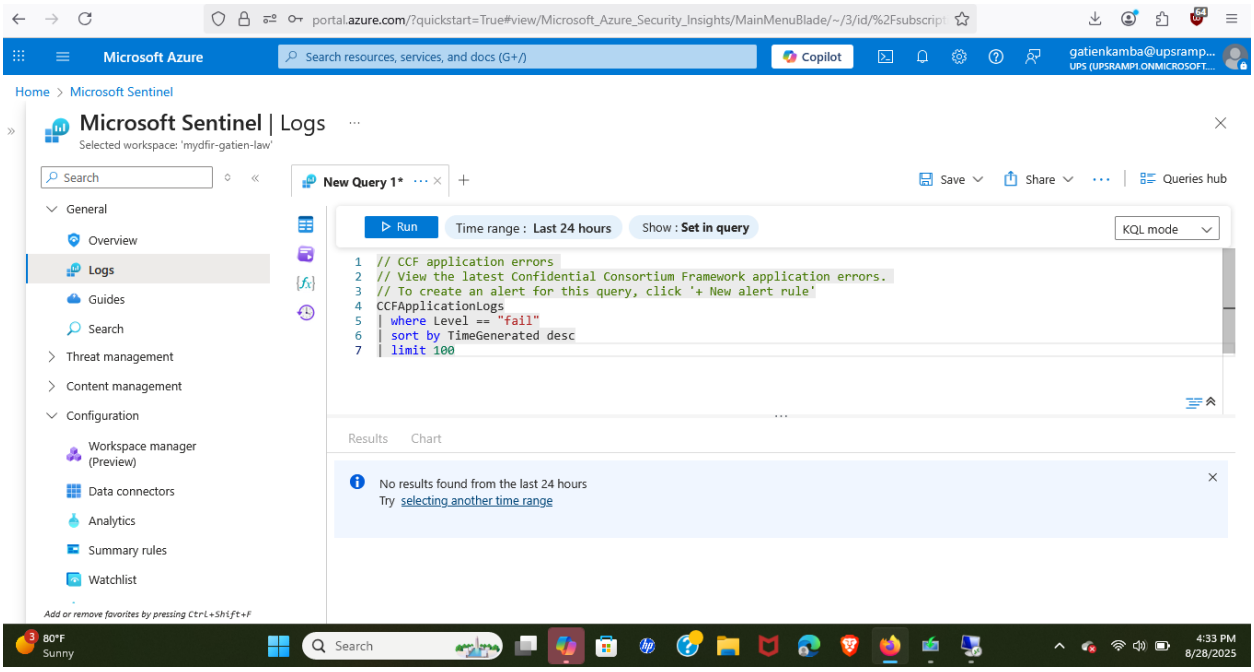
4. Sentinel Logs / KQL

I opened Microsoft Sentinel Logs and worked with the KQL query interface.

The first query that was presented was an example of a query run on application logs. The key aspect of this task was gaining experience with the Sentinel log-query interface and learning how to use KQL for investigation.

Lab MyDFIR copy.docx

SOC skill: SIEM log investigation and KQL.



5. Event ID Analysis

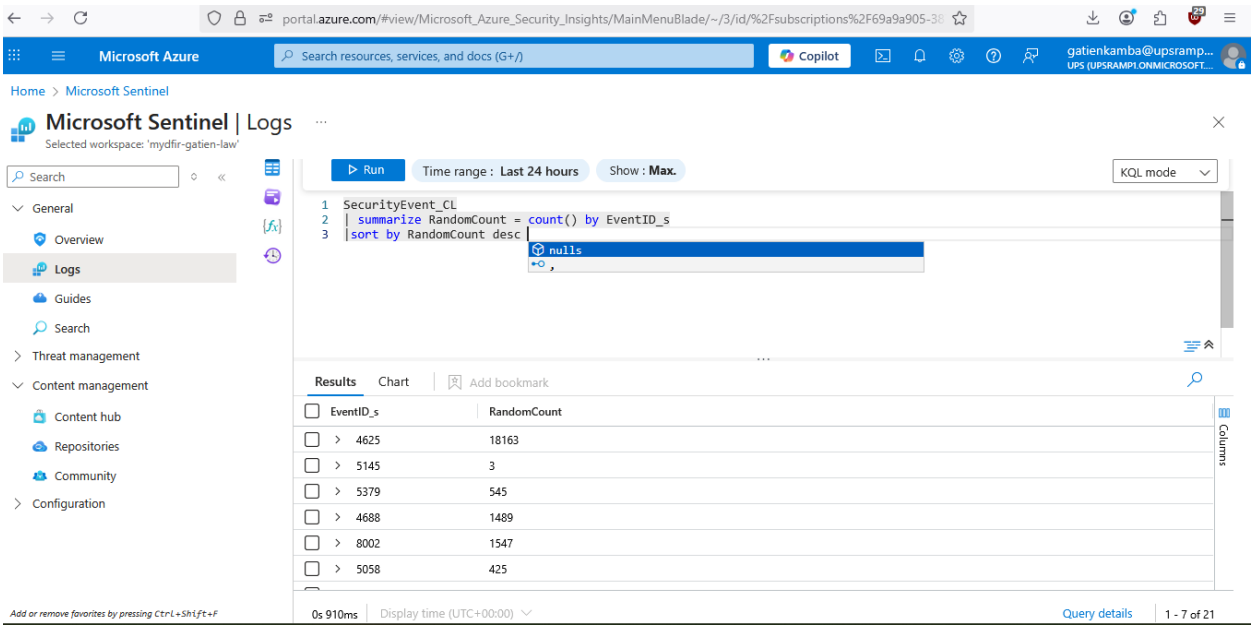
I ran the query for SecurityEvent_CL and summarized the events based on Event ID.

This query basically answers:

What are the most common Windows security events happening?

This helps the analyst know what is going on in the environment and what events need to be investigated further.

SOC Skill: Windows Event Log analysis.



6. Investigating Failed Logons

I then narrowed the investigation to **Event ID 4625**, which represents a failed logon.

The query:

SecurityEvent_CL

| where EventID_s == "4625"

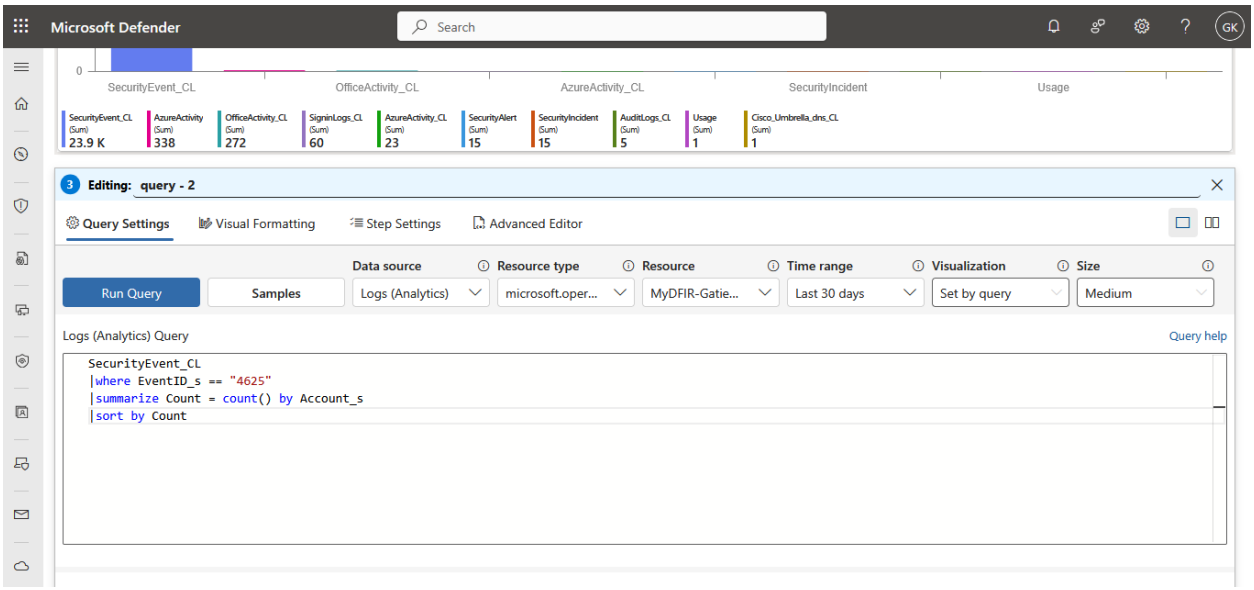
| summarize Count = count() by Account_s

| sort by Count

This groups failed authentication events by account.

Why this matters: A large number of failed logons against an account can be an indicator of password spraying or brute-force activity.

SOC skill: Authentication investigation and KQL.

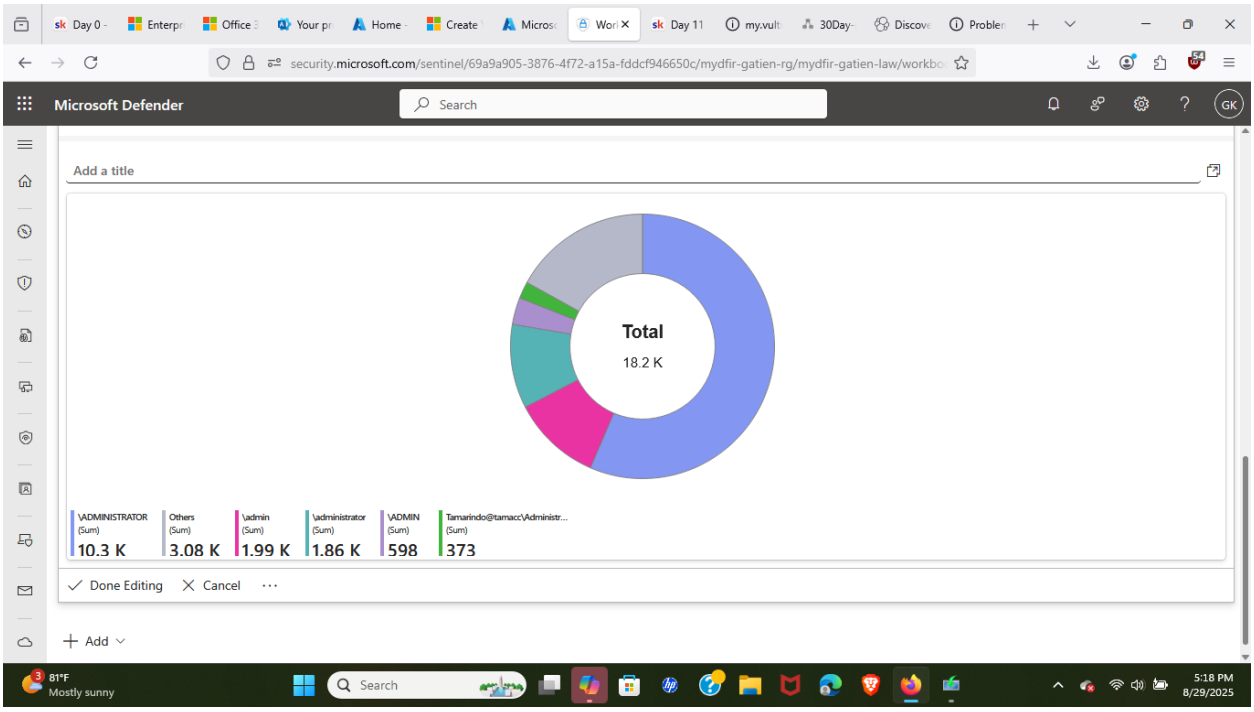


7. Creating a Visualization

I developed a visualization/dashboard based on the authentication dataset.

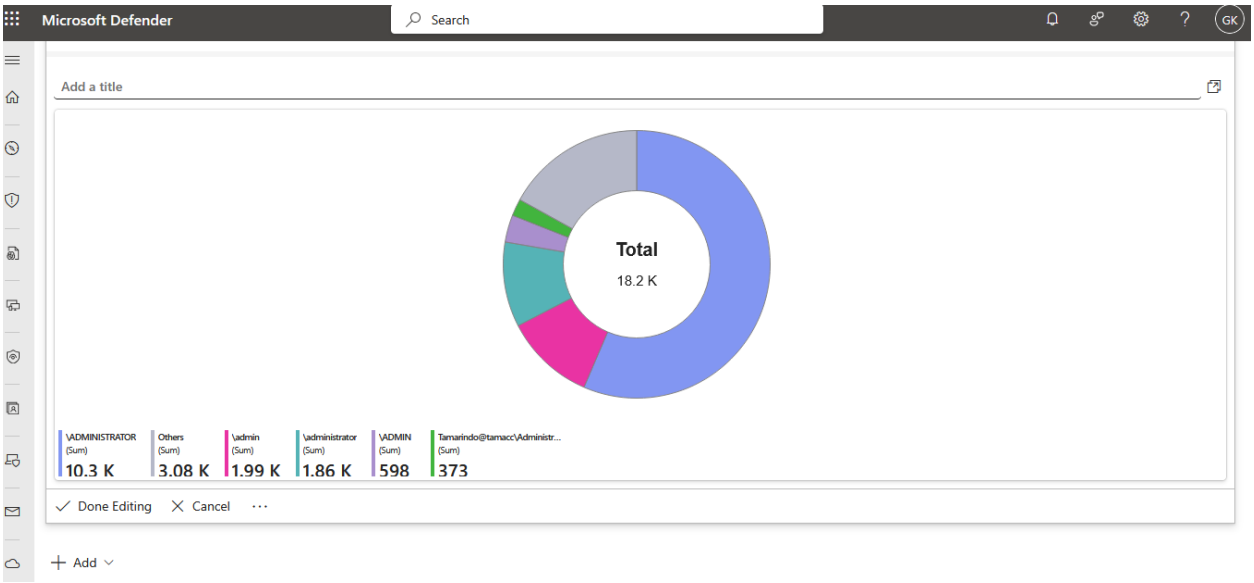
The visualization helps to easily identify the accounts that have high activity levels.

SOC Skill: Visualization and communication of security data insights.



8. Reviewing the Authentication Results

I looked at the visualization and analyzed the activity from various accounts.
This was done in order to find accounts that had an unusual number of authentications.
SOC skill: Anomalous behavior detection.

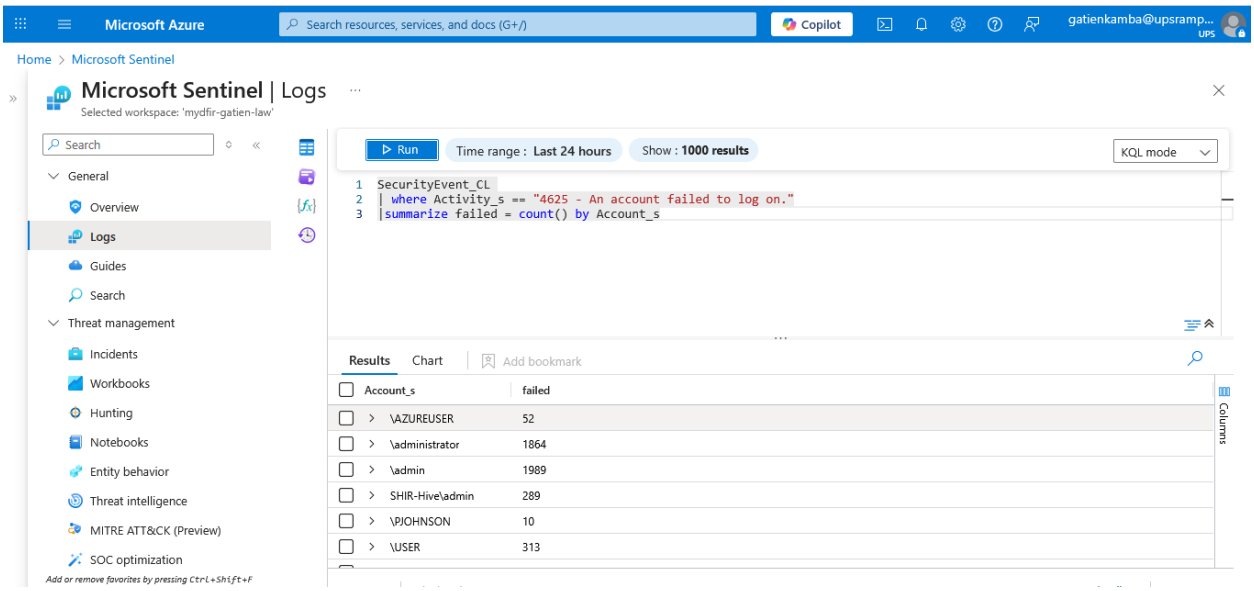


9. Identifying Accounts with Failed Logons

I refined the query to specifically identify accounts associated with failed logon activity.
The results showed accounts such as:

- administrator
- \admin
- Other user/service accounts

This provides the analyst with targets for further investigation.
SOC skill: Account-based threat investigation.



- **Detection Engineering**

10. Creating the Failed Logon Detection Rule

I created a **Scheduled Analytics Rule** called:

MyDFIR-Gatien-FailedLogonAlert

The description identifies the purpose as:

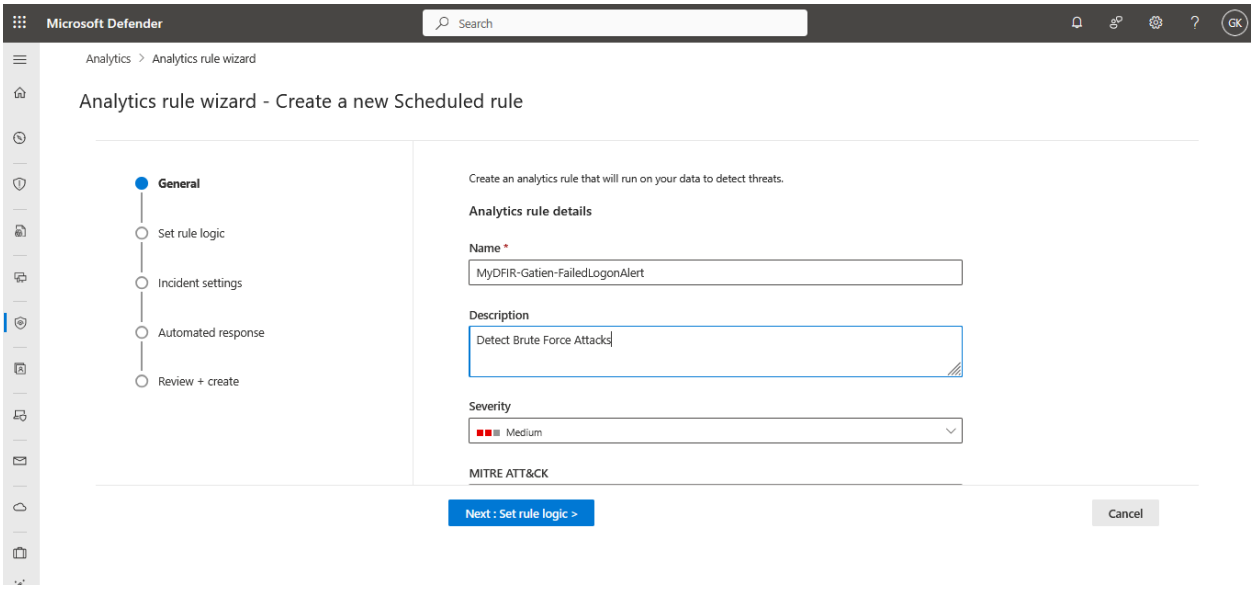
Detect Brute Force Attacks

I also assigned a **medium severity**.

This converts the investigation query into an automated detection.

SOC skill: Detection engineering and alert creation.

Lab MyDFIR copy.docx



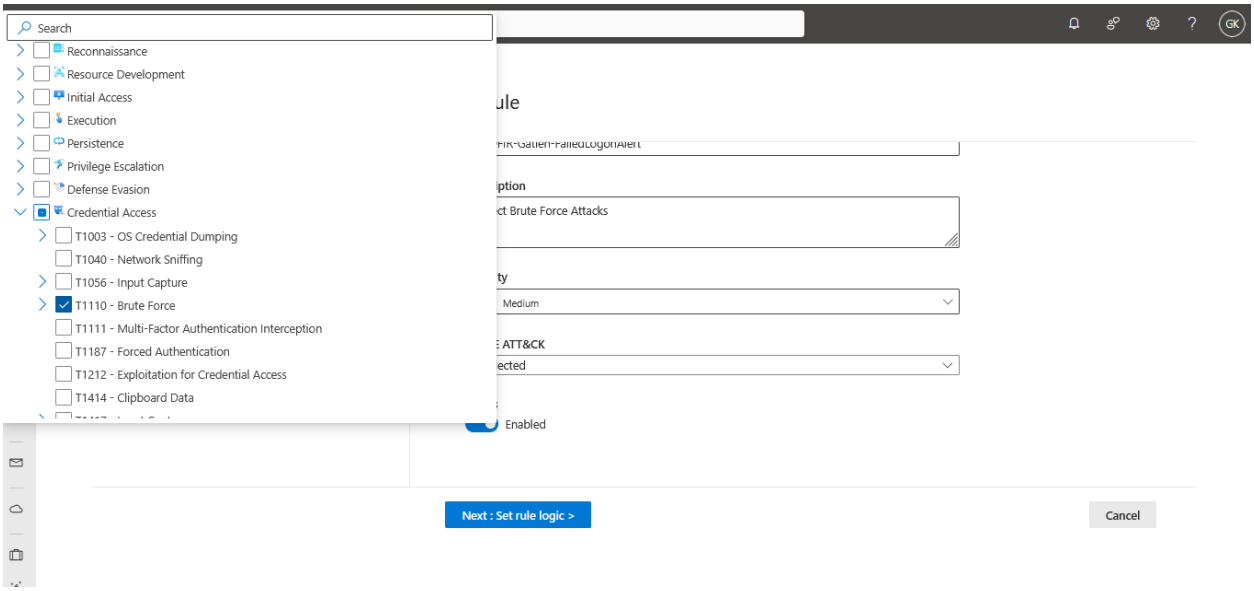
11. MITRE ATT&CK Mapping

I mapped the detection to the appropriate MITRE ATT&CK technique:

T1110 — Brute Force

This gives the alert additional threat-intelligence context and helps security teams understand the attacker's behavior being detected.

SOC skill: MITRE ATT&CK mapping.

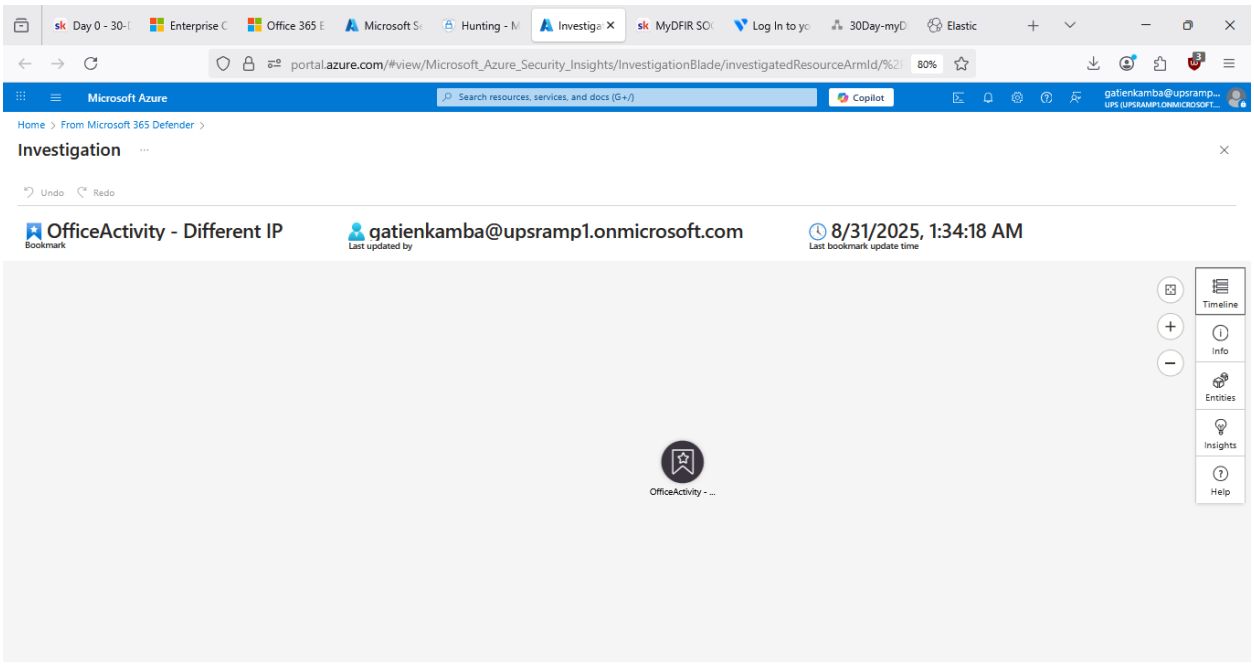


12. Investigating an Office 365 Event

I opened an investigation involving **OfficeActivity** and reviewed activity associated with an account and IP information.

This demonstrates how an analyst can pivot from a security event into an investigation timeline.

SOC skill: Cloud/SaaS investigation and event correlation.

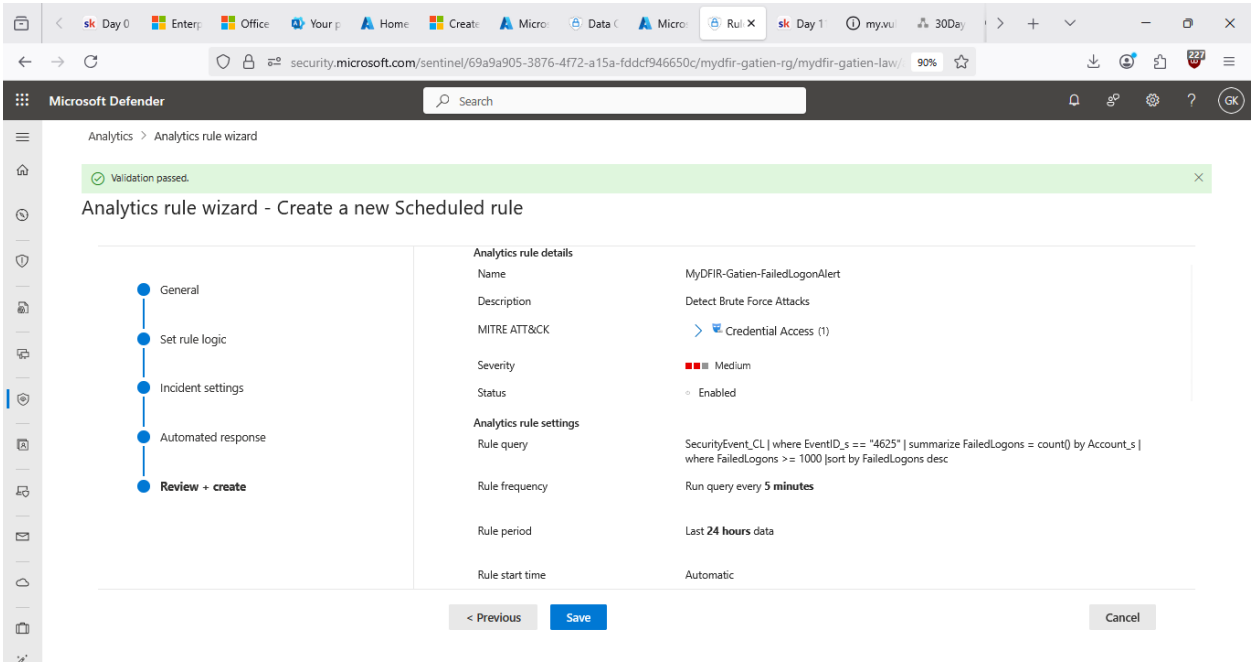


13. Refining the Failed-Logon Investigation

I used additional filtering against Event ID 4625 and a specific collection time.

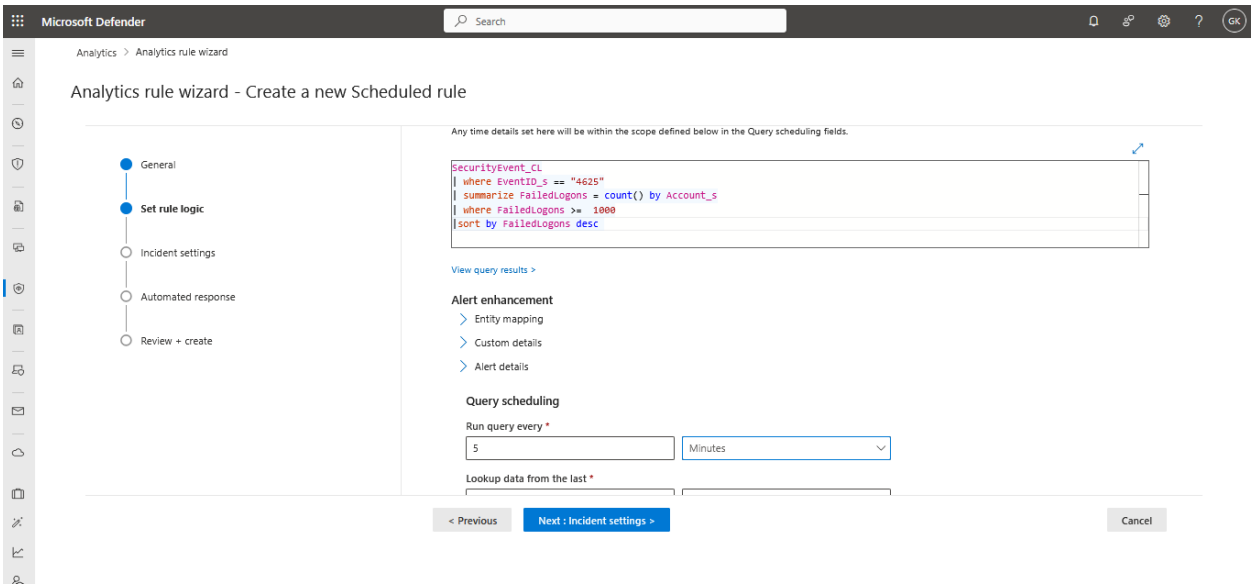
The goal was to narrow down the results and determine which accounts were involved during the relevant period.

SOC skill: KQL filtering and timeline investigation.



14. Reviewing the Completed Detection Rule

The analytics rule was validated successfully.
The detection logic was essentially:
SecurityEvent_CL
| where EventID_s == "4625"
| summarize FailedLogons = count() by Account_s
| where FailedLogons >= 1000
| sort by FailedLogons desc
The rule was configured to run every **5 minutes** and look back over the previous **24 hours**.
SOC skill: Building an automated brute-force detection.
Lab MyDFIR copy.docx



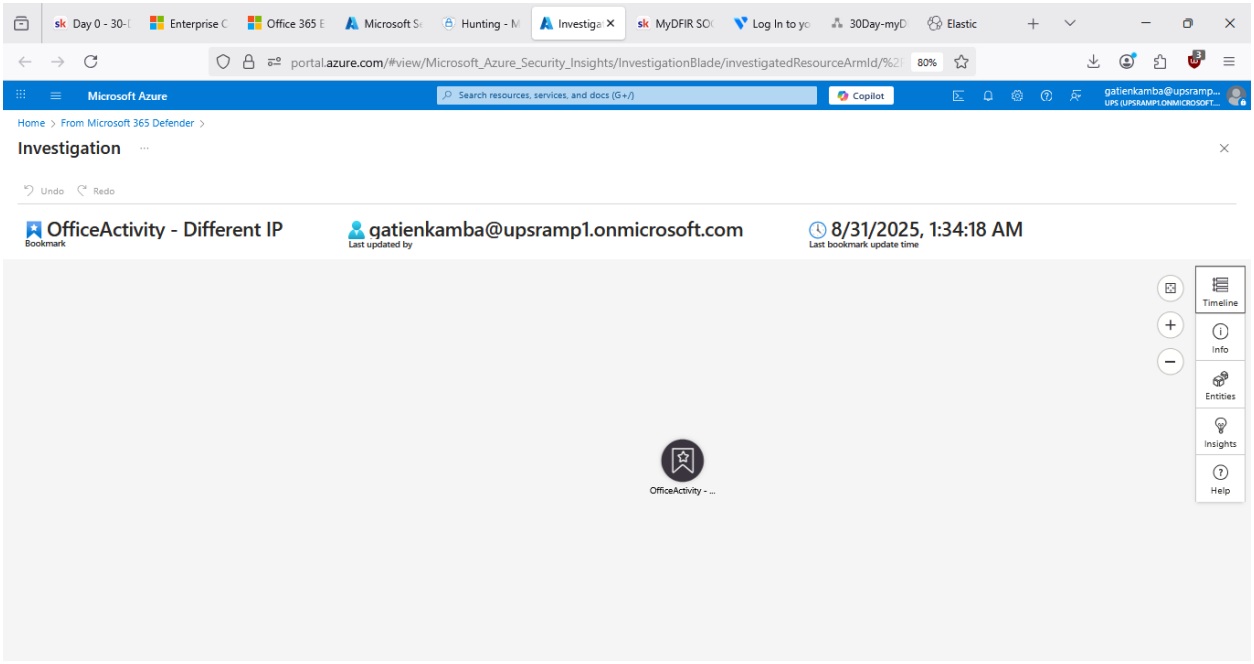
15. Configuring Query Scheduling

I configured the scheduling parameters for the analytics rule.
The important settings include:

- How frequently the query runs
- How far back Sentinel looks for activity
- The query used for detection
- Alert configuration

This allows Sentinel to continuously monitor the environment rather than requiring a SOC analyst to manually run the query.

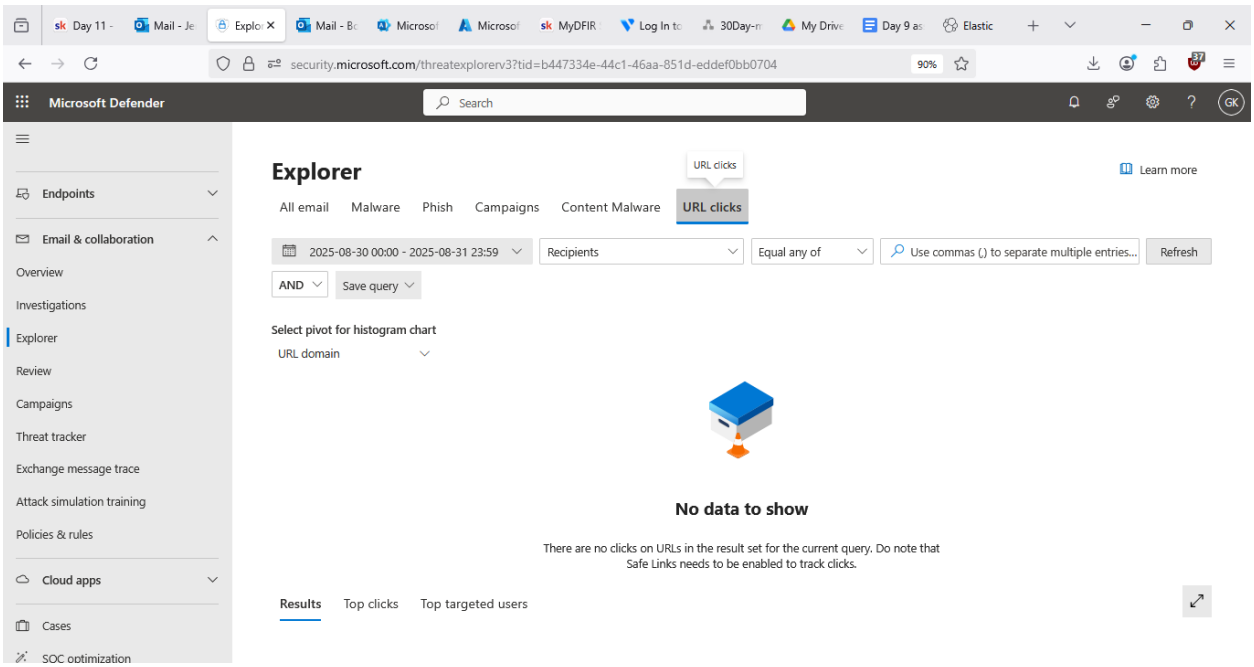
SOC skill: SIEM automation.



- **Microsoft Defender Email Security**

16. Threat Explorer / URL Investigation

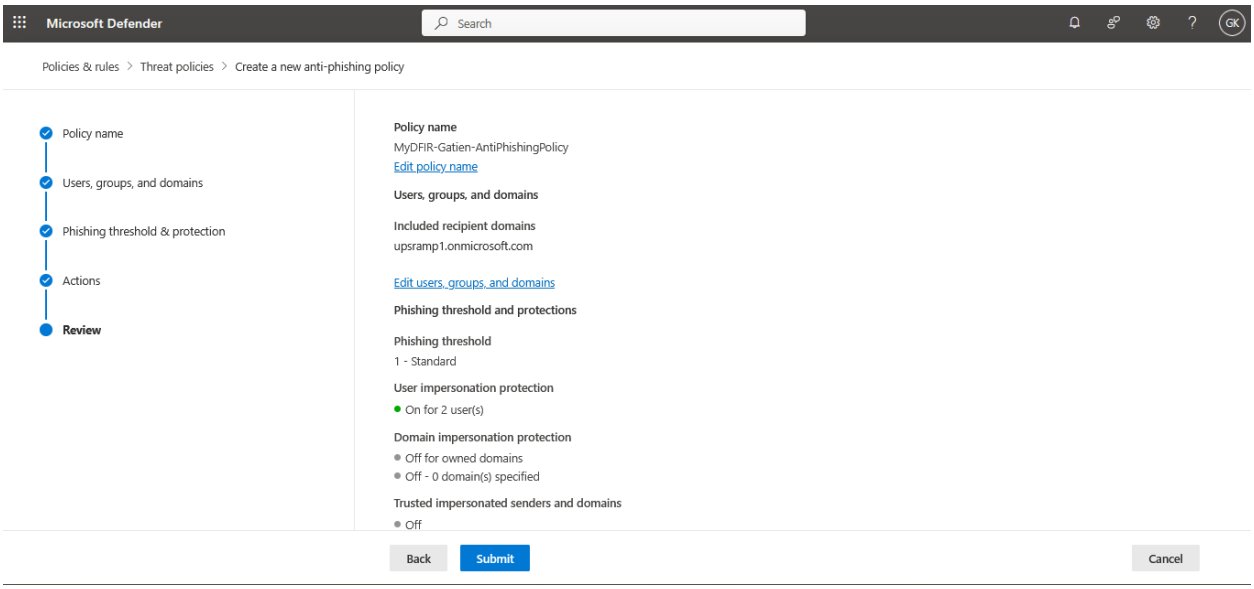
I used **Microsoft Defender Threat Explorer** to investigate email and URL activities.
The screen shows URL-click investigation capabilities and indicates that Safe Links must be enabled to track URL clicks.
SOC skill: Email security investigation and phishing analysis.



17. Creating an Anti-Phishing Policy
I created an anti-phishing policy named:
MyDFIR-Gatien-AntiPhishingPolicy
I configured phishing protection settings, including:

- Phishing threshold
- User impersonation protection
- Domain impersonation protection
- Trusted senders/domains

SOC skill: Email security policy configuration.

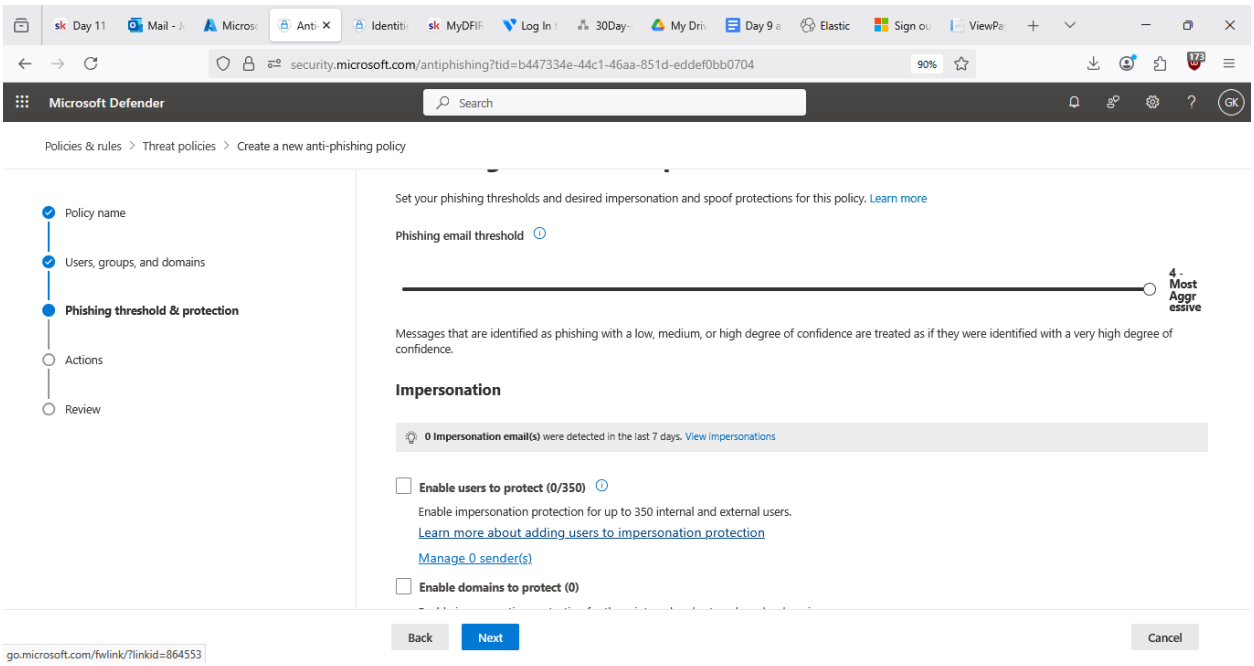


18. Configuring Phishing Protection

I configured the phishing threshold and impersonation protection.
The purpose is to increase protection against:

- Phishing emails
- User impersonation
- Domain impersonation
- Spoofing

SOC skill: Microsoft Defender for Office 365 security configuration.



19. Creating a Safe Links Policy

I created:

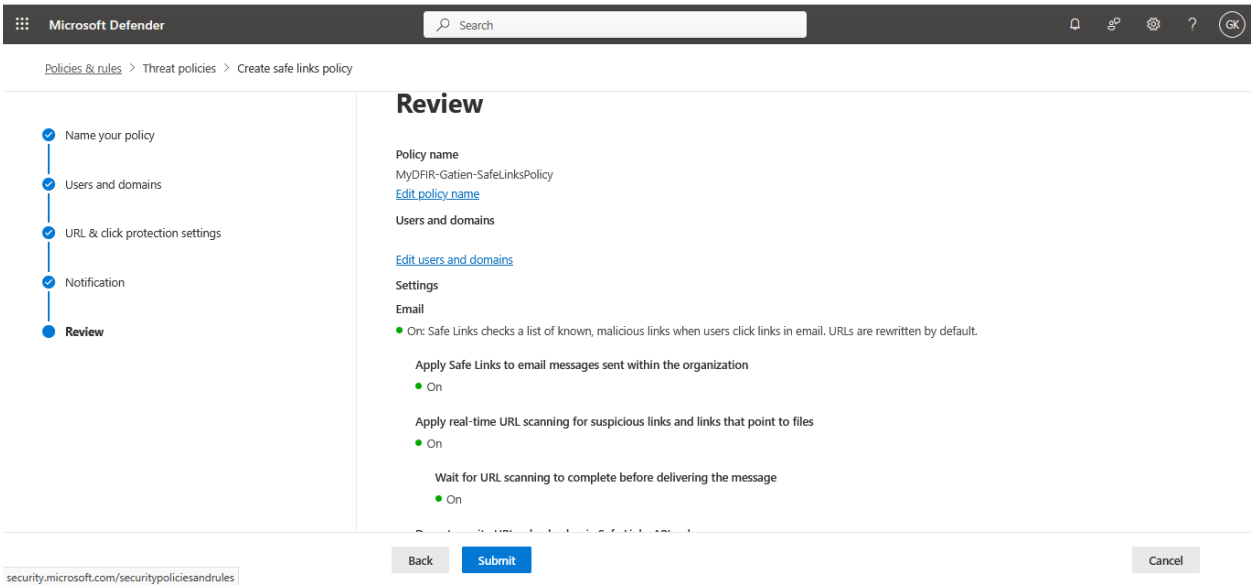
MyDFIR-Gatien-SafeLinksPolicy

The policy was configured to protect users from malicious URLs.

Important settings included:

- URL scanning
- Real-time URL scanning
- URL rewriting
- Scanning links before delivery

SOC skill: URL protection and phishing defense.

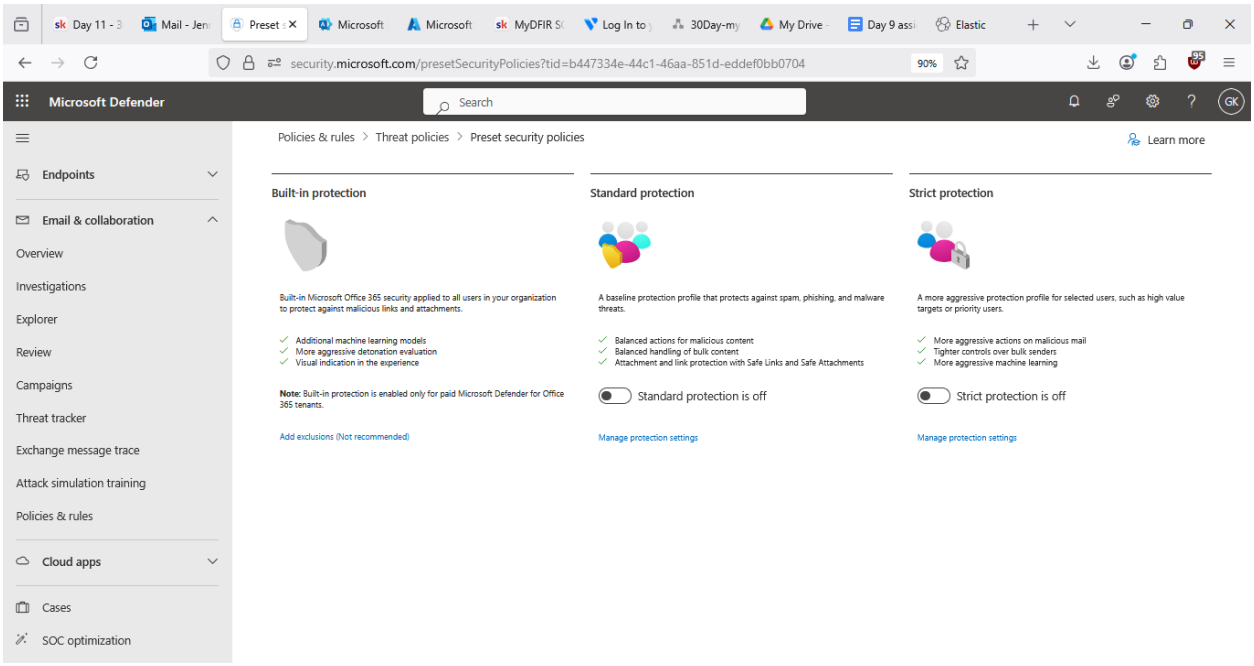


20. Reviewing Preset Security Policies

I reviewed Microsoft's **Preset Security Policies**, including:

- Standard protection
- Strict protection

This provided an understanding of Microsoft's built-in security baselines for email protection.
SOC skill: Security-policy management.

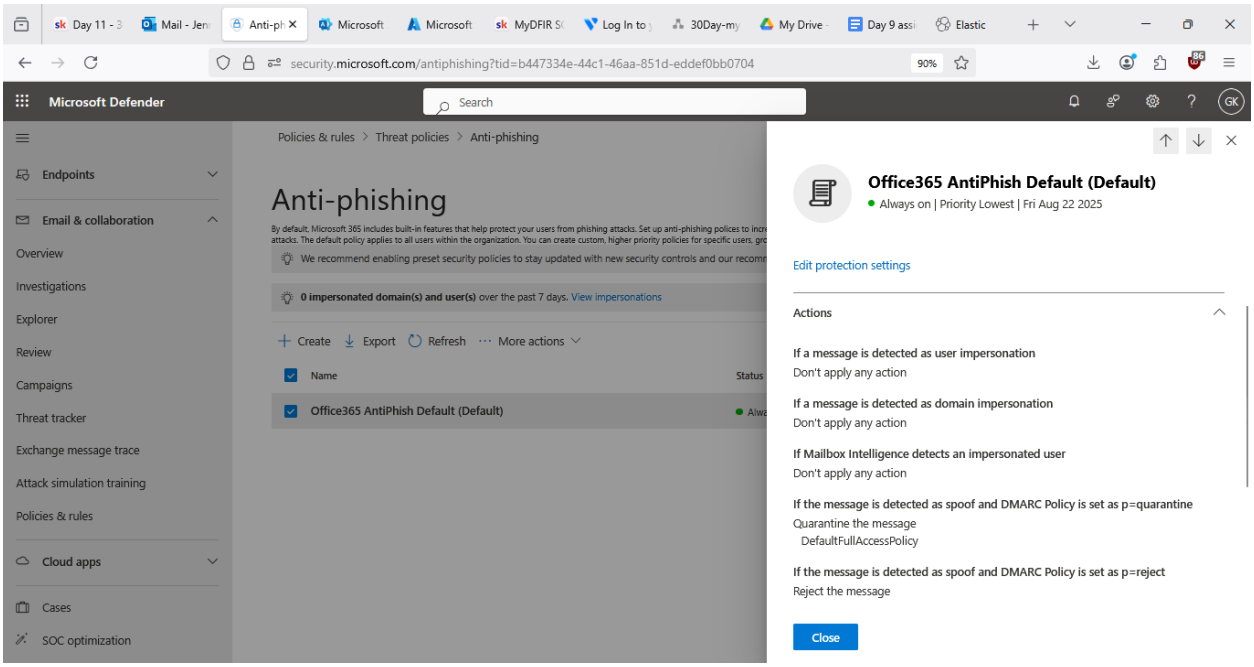


21. Reviewing the Default Anti-Phishing Policy

I reviewed the existing **Office365 AntiPhish Default** policy.

This allowed me to understand how existing anti-phishing controls were configured and how actions are applied when Microsoft detects impersonation or spoofing.

SOC skill: Security-policy analysis.



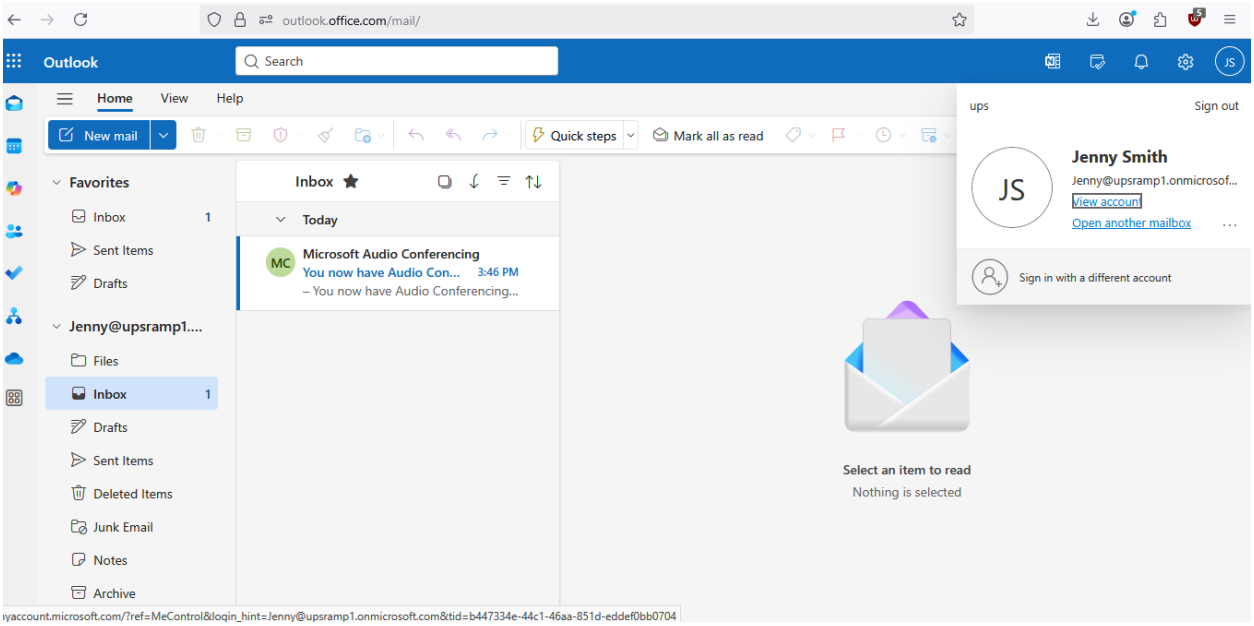
- **Phishing Simulation**

22. Test Email Environment

I accessed the Outlook environment to prepare for testing the phishing controls.

The objective was to use a controlled email environment to validate security policies.

SOC skill: Security control validation.

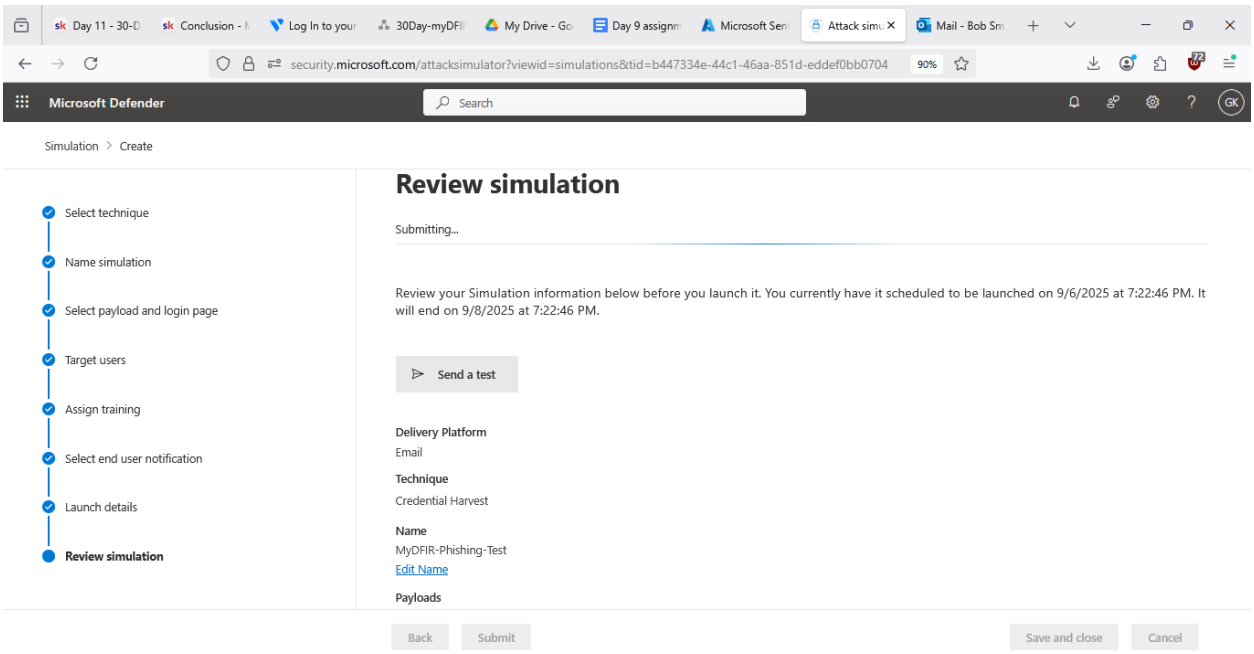


23. Creating a Phishing Simulation

I created a phishing simulation in **Microsoft Attack Simulation Training**. The simulation was configured with:

- Simulation name: MyDFIR-Phishing-Test
- Technique: **Credential Harvesting**
- Test payload/login page
- Target users
- End-user notification
- Launch schedule

SOC skill: Phishing simulation and security awareness testing.

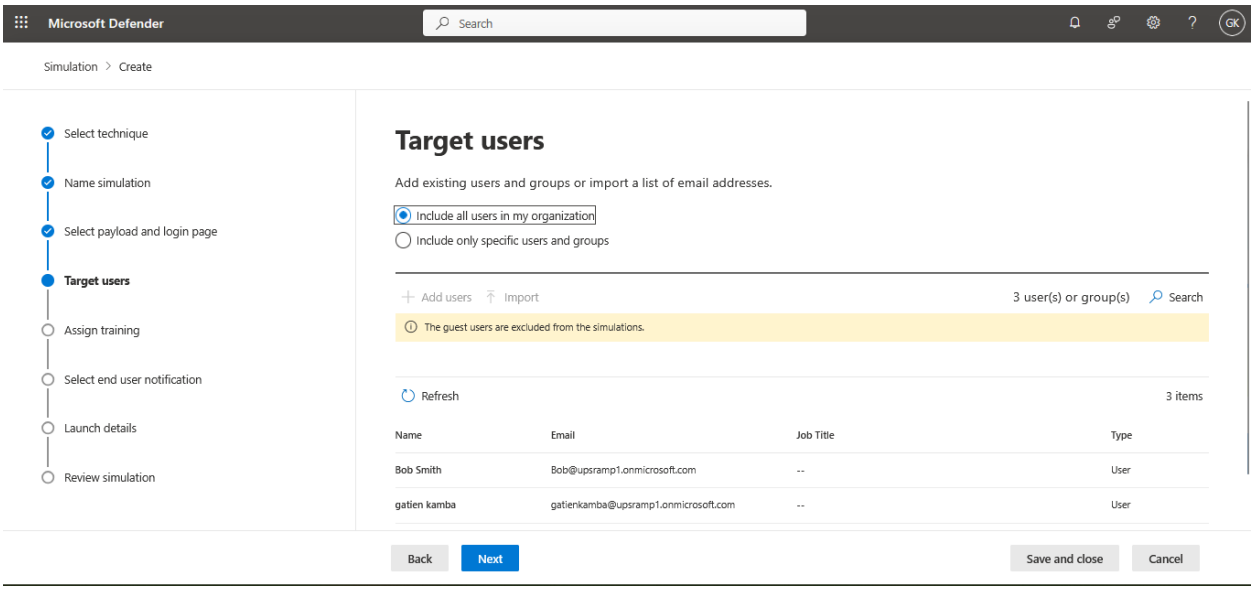


24. Selecting Target Users

I selected specific users for the phishing simulation rather than automatically targeting everyone. The screenshot shows users such as Bob Smith and other test accounts.

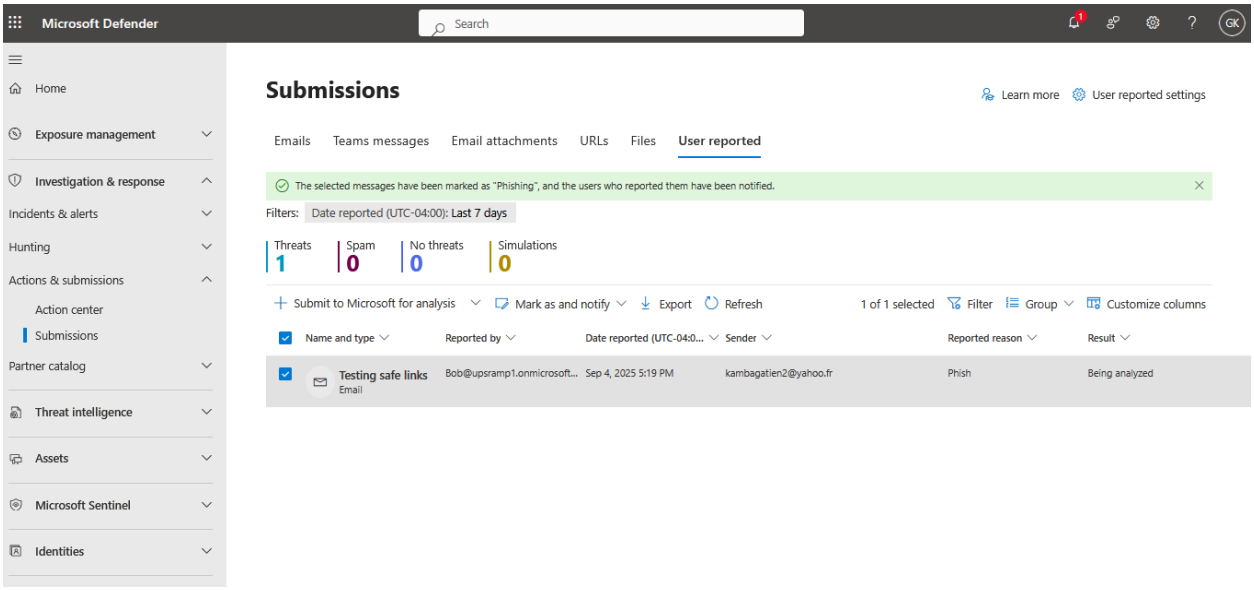
Why this matters: Security teams should carefully scope simulations to prevent unintended impact.

SOC skill: Controlled security testing.



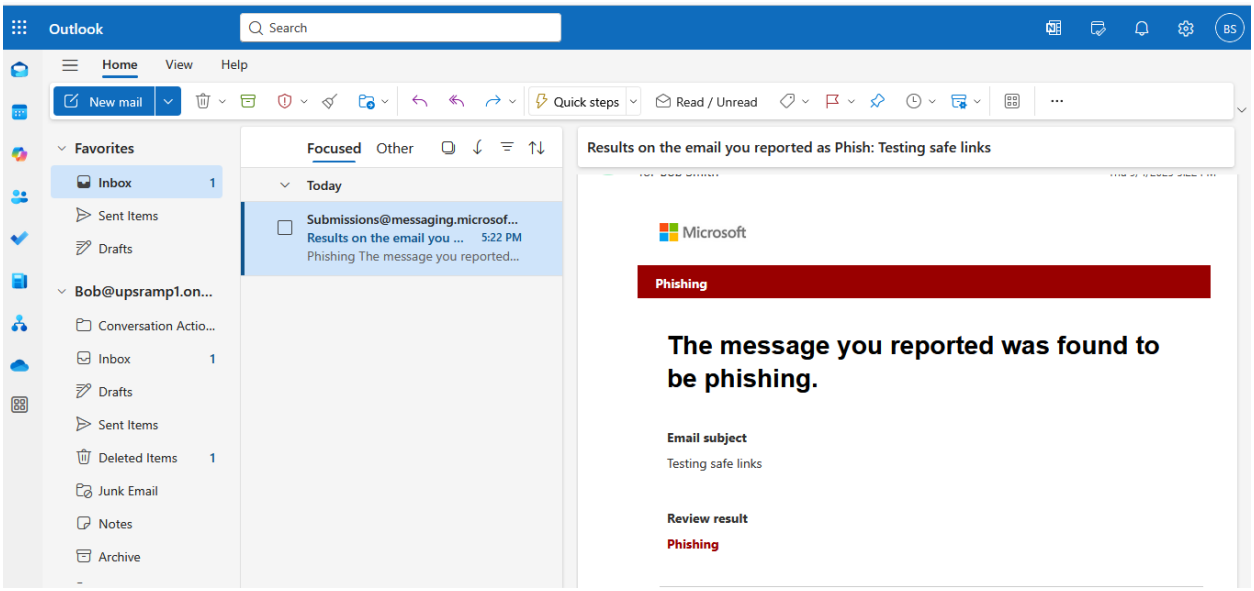
25. User-Reported Phishing

I reviewed **User reported** submissions in Microsoft Defender.
A test message was reported as phishing and appeared in the investigation/submission area.
This demonstrates the SOC workflow where an employee reports a suspicious email, and the security team investigates it.
SOC skill: Phishing triage.



26. Confirming the Phishing Result

The reported message was analyzed, and Microsoft determined that the message was phishing.
This demonstrates the complete workflow:
User reports email → Security team analyzes → Threat classification → User receives result
SOC skill: Phishing investigation and validation.



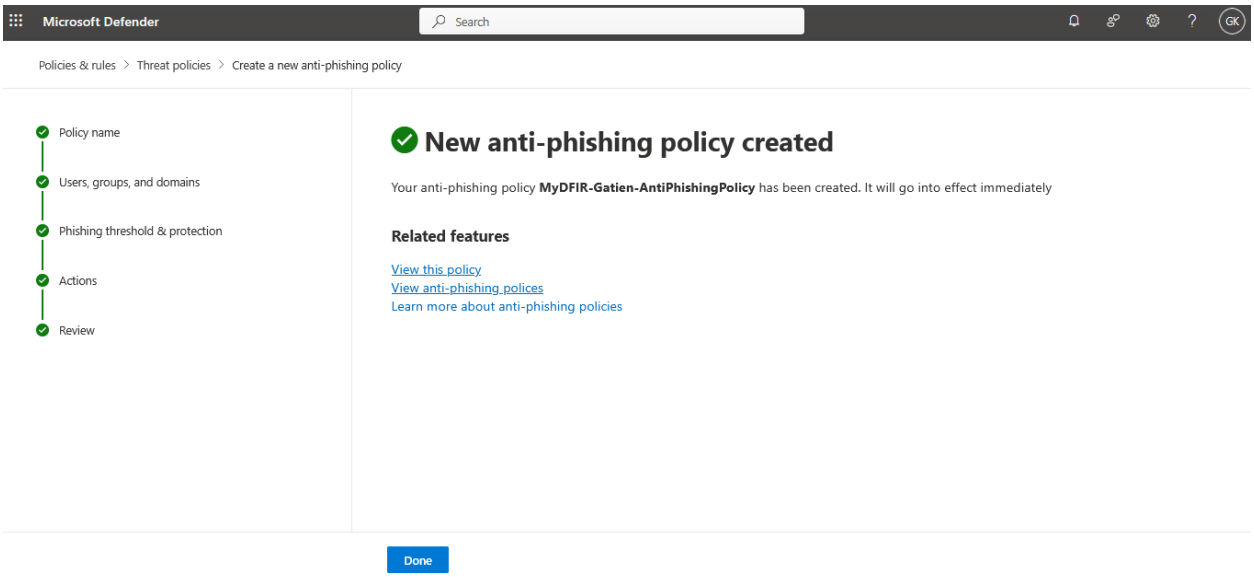
27. Anti-Phishing Policy Successfully Created

Microsoft Defender confirmed that:

MyDFIR-Gatien-AntiPhishingPolicy

was successfully created and would take effect immediately.

This proves that security control was successfully deployed.

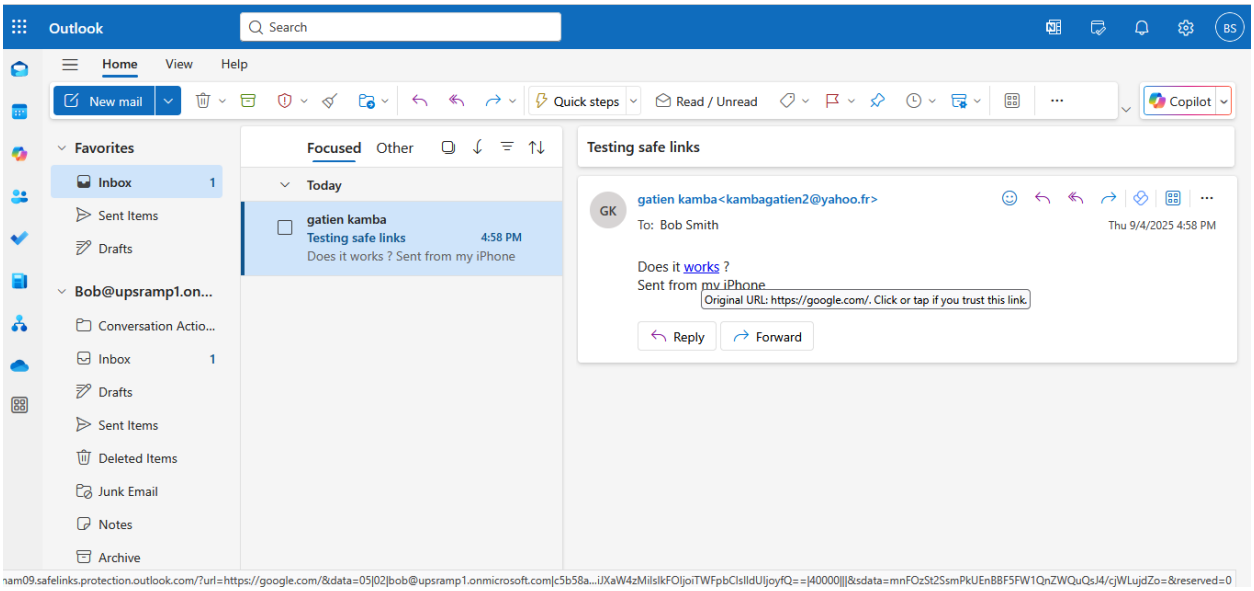


28. Testing Safe Links

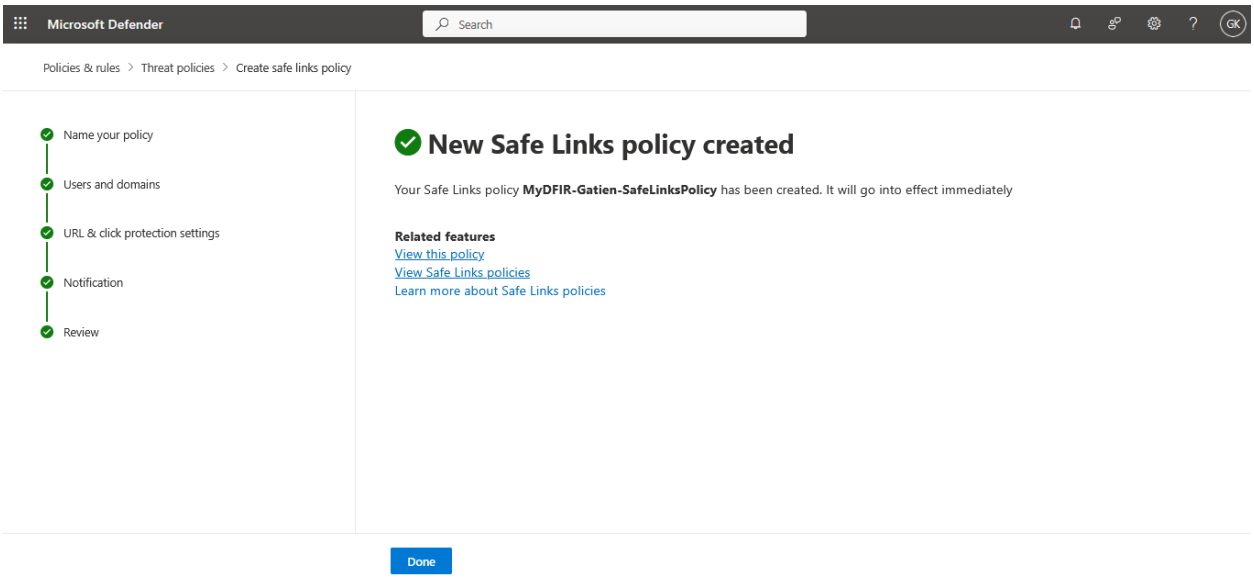
I sent a test email containing a URL.

The URL was processed through Microsoft's **Safe Links** protection.

The original URL was rewritten to a Microsoft Safe Links URL.
SOC skill: Validating URL protection controls.



29. Safe Links Policy Successfully Created
Microsoft confirmed that:
MyDFIR-Gatien-SafeLinksPolicy
was successfully created.
This completed the Safe Links configuration portion of the lab.



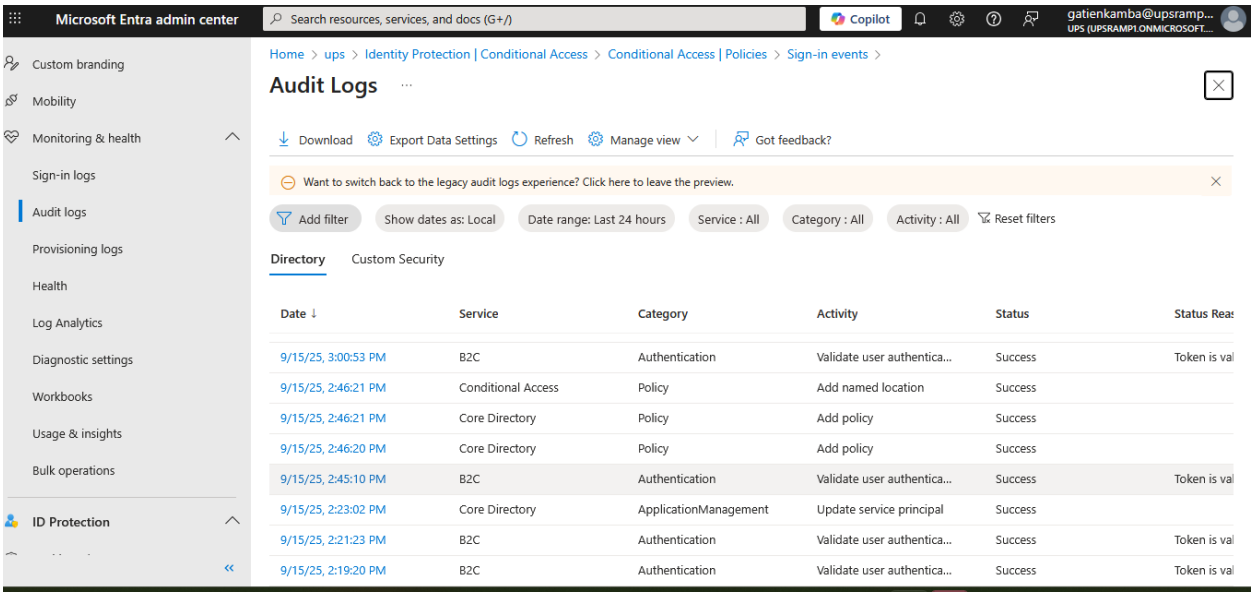
- **Identity & Endpoint Security**

30. Entra ID Audit Logs

I reviewed **Microsoft Entra ID Audit Logs**.
These logs provide visibility into administrative and identity-related activities such as:

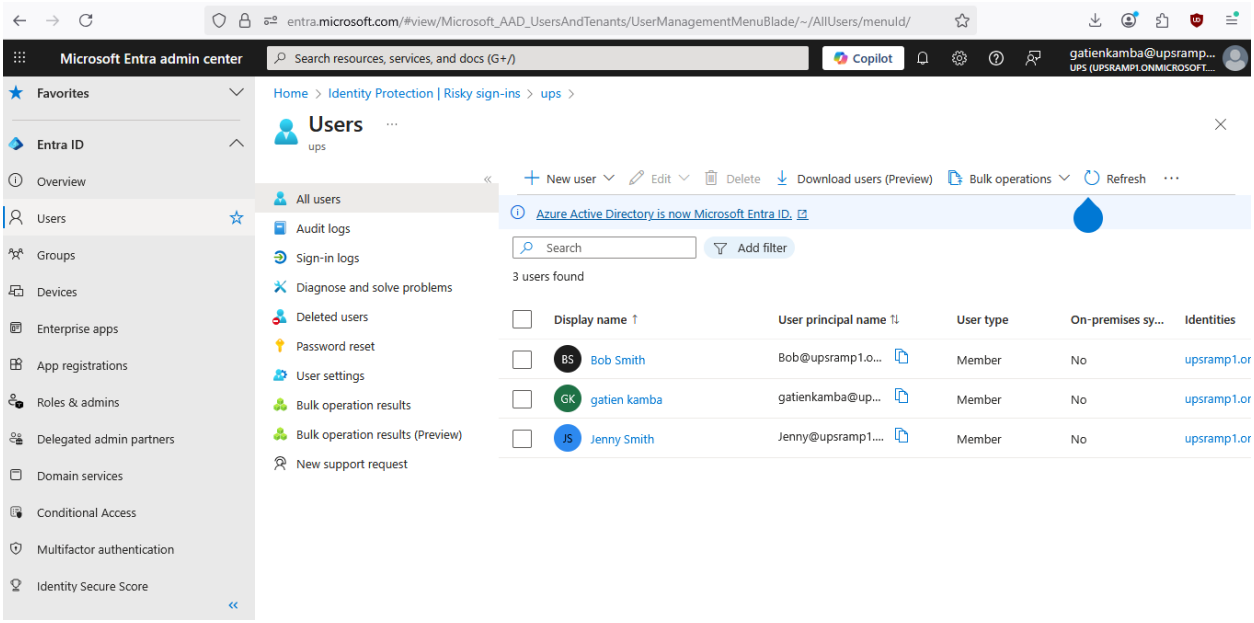
- Policy changes
- Authentication activity
- Application/service-principal changes
- Directory changes

SOC skill: Identity monitoring and audit-log investigation.



31. Reviewing Entra ID Users

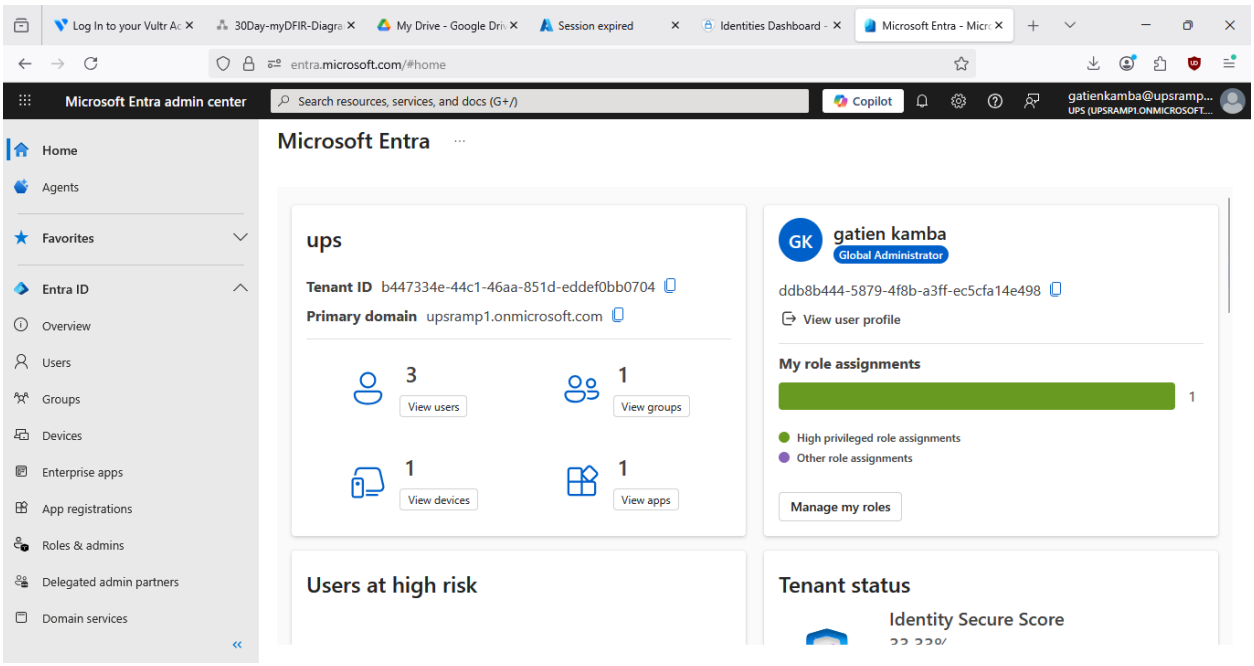
I reviewed the users configured in the Microsoft Entra environment.
The environment contained several test users.
This is important because SOC analysts need to understand which identities exist in an environment when investigating suspicious authentication activity.
SOC skill: Identity investigation.



32. Microsoft Entra Overview
I reviewed the overall Entra ID environment, including:

- Users
- Groups
- Devices
- Applications
- Roles
- Identity protection
- Secure score

This provides an understanding of the organization's identity infrastructure.
SOC skill: Identity and access security



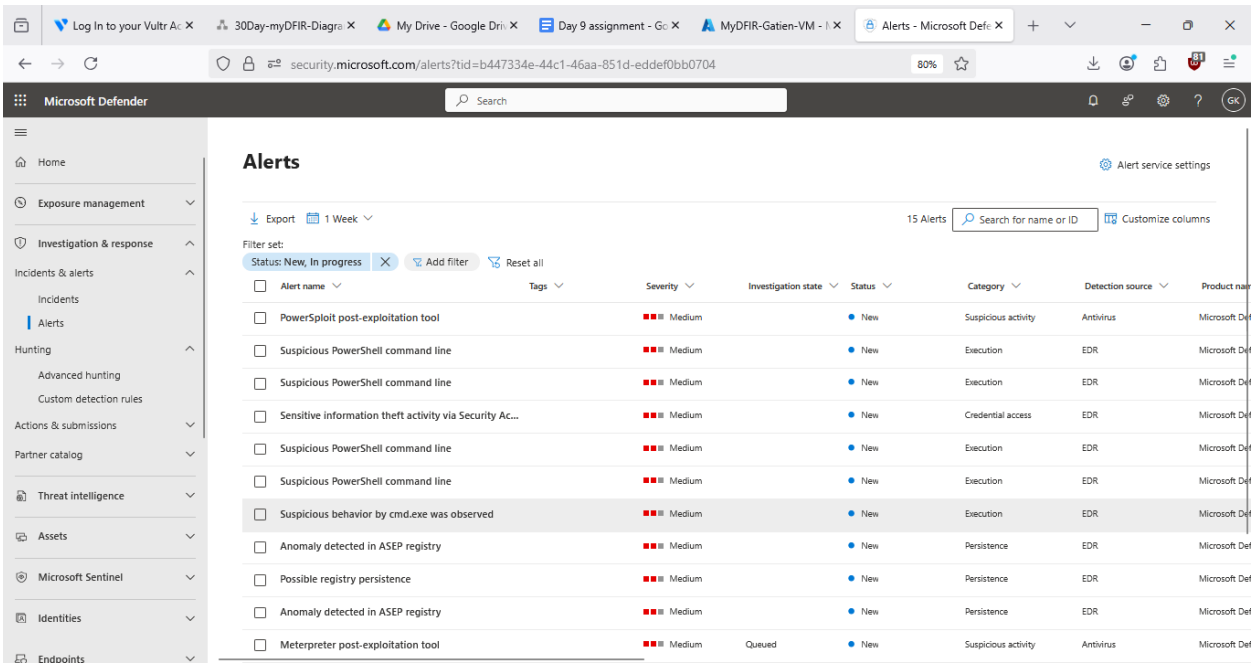
Microsoft Defender Endpoint

33. Reviewing Security Alerts

I reviewed the Microsoft Defender alerts dashboard.
The environment contained alerts related to suspicious activity such as:

- Suspicious PowerShell
- Post-exploitation activity
- Registry persistence
- Suspicious command-line activity
- Potential credential/security-related activity

This demonstrates how a SOC analyst reviews endpoint alerts and prioritizes suspicious activity.
SOC skill: EDR alert triage and investigation.



34. Attack Surface Reduction

I accessed **Microsoft Intune → Endpoint Security → Attack Surface Reduction**.

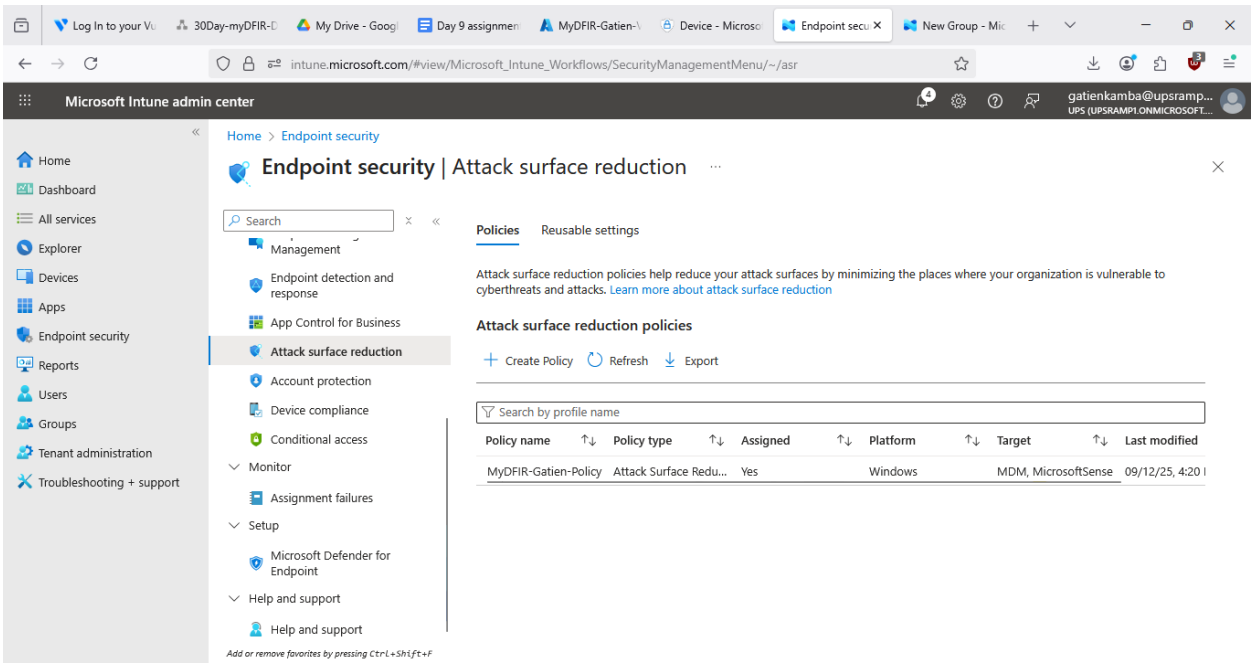
An ASR policy named:

MyDFIR-Gatien-Policy

was configured.

Attack Surface Reduction policies help reduce the techniques attackers can use to compromise endpoints.

SOC skill: Endpoint hardening and preventive security controls.

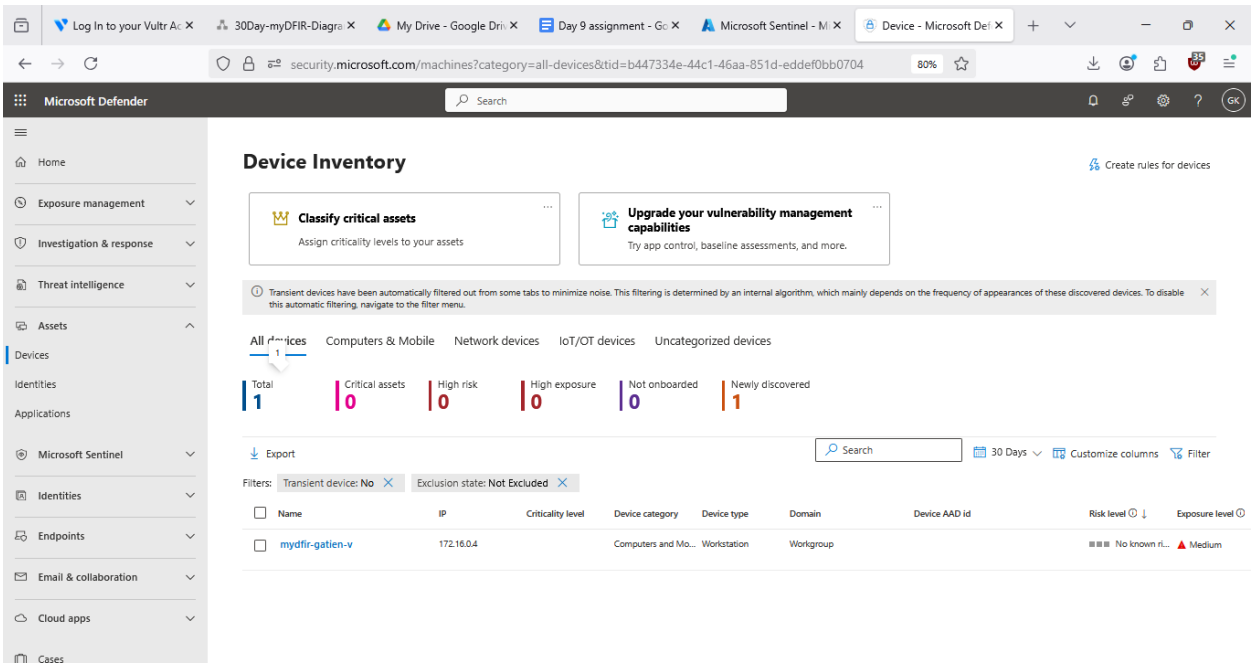


35. Defender Device Inventory

I reviewed the **Microsoft Defender Device Inventory**.
This provides visibility into:

- Computers
- Mobile devices
- Network devices
- IoT/OT devices
- Risk level
- Exposure level
- Critical assets

SOC skill: Asset visibility and endpoint monitoring.

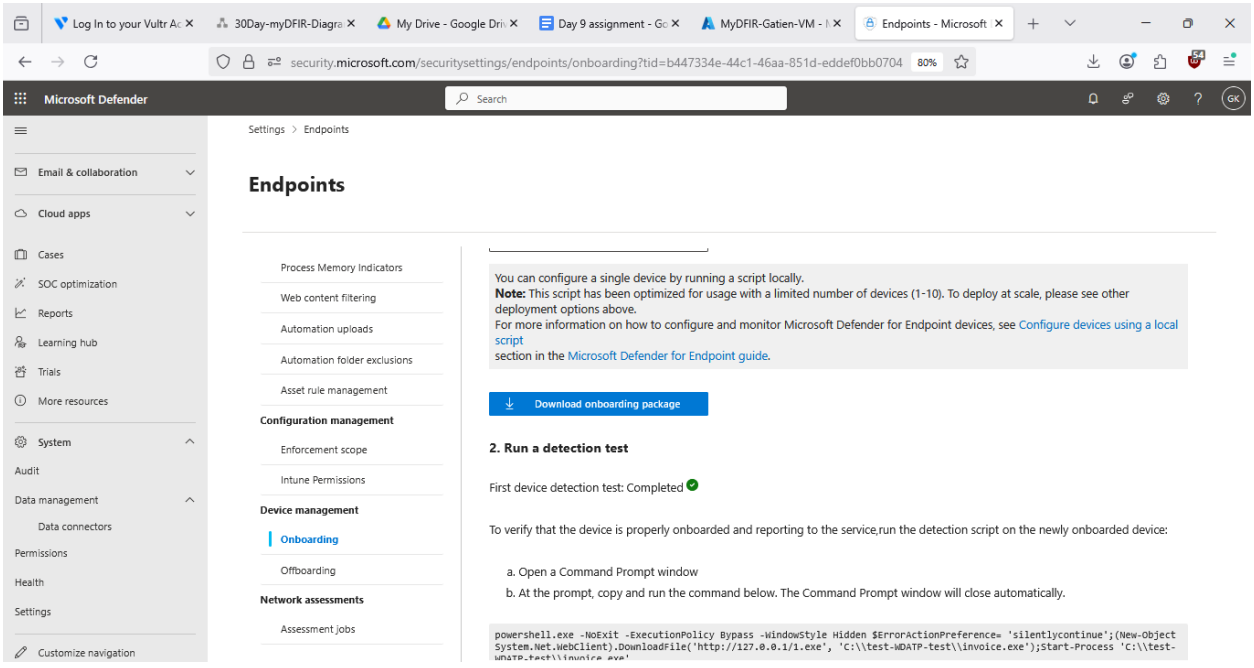


36. Microsoft Defender for Endpoint Onboarding

I reviewed the Defender for Endpoint onboarding configuration.

The screen shows the process for onboarding a device and running a detection test to confirm that the endpoint is communicating with Microsoft Defender.

SOC skill: Endpoint onboarding and security monitoring deployment.



37. Reviewing the Device Inventory Again

Finally, I returned to the Defender device inventory to verify the endpoint environment and review the available devices and security information.

This closes the endpoint-security portion of the lab.

SOC skill: Endpoint visibility and security validation.

